

Stack Smash

Bối cảnh (Context)

Một sinh viên năm nhất vừa nộp bài tập lớn môn Lập trình C: Một phần mềm dòng lệnh quản lý thư viện sách. Phần mềm yêu cầu người dùng nhập tên sách bằng lệnh `gets()`. Vị giáo sư già cảnh báo rằng phần mềm này rất nguy hiểm và có thể bị hacker chiếm quyền điều khiển toàn bộ máy tính, nhưng cậu sinh viên vẫn chưa hiểu vì sao.

Trong code có một hàm bí mật tên là `print_flag()` không bao giờ được gọi đến.

Mục tiêu (Objective)

- **Nhiệm vụ:** Tìm cách chuyển hướng luồng thực thi của chương trình để gọi hàm `print_flag()`.
- **Vấn đề / Lỗi hỏng: Buffer Overflow (Tràn bộ đệm).** Hàm `gets()` không kiểm tra độ dài chuỗi nhập vào. Kẻ tấn công có thể nhập một chuỗi dài hơn kích thước khai báo (ví dụ 64 bytes), khiến dữ liệu tràn ra ngoài vùng đệm trên Stack. Việc ghi đè này sẽ thay đổi địa chỉ trả về (Return Address / Saved RIP) của hàm hiện tại, điều khiển chương trình nhảy tới địa chỉ của hàm `print_flag()`.
- **Flag:** Hàm `print_flag()` được thực thi sẽ in ra Flag.

Gợi ý (Hints)

- Xác định kích thước bộ đệm (Offset) bằng cách nhập một chuỗi tuần tự (ví dụ `AAAABBBB...`) và xem chương trình crash ở địa chỉ nào.
- Dùng công cụ `gdb` hoặc `pwndbg` để tìm địa chỉ thật của hàm `print_flag()`.